

CWE AI Working Group

Meeting Minutes

February 28, 2025

Attendance

- Monika Akbar
- Sven Cattell
- Steve Christey Coley
- Chris Coffin
- João Galego
- Erick Galinkin
- Chris Gourley
- Martin Hodo
- Almir Mesic
- Kevin Monette
- Ahmed Nagy
- Monika Akbar
- Caroline Rocha
- Ahmed Shah
- Pieter van Wassenauer

Agenda

- Meeting Introduction
- Status Updates
- Subgroup Status
- Focus on New-Entry Development

Meeting Notes:

Meeting Introduction: Steve introduced the February 28th, 2025 meeting of the AI Working Group, and outlined the agenda, which included status updates for the working group, the status of the new subgroups, and a primary focus on new-entry submissions.

Status Updates:

- **New Members:** João Galego and Almir Mesic introduced themselves to the WG. João introduced himself as the head of AI Operations and principal AI engineer at Critical Software. Almir introduced himself as a senior manager for cybersecurity at Valaris, an offshore drilling company in the oil and gas sector.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- **Next CWE Release:** Steve announced a release date of April 3, 2025, just before VulnCon 2025 (April 7-10), for the next CWE release. This will include the public release of the content development repository (CDR).
- **Subgroup Meetings Schedule:** Steve explained that subgroup meetings will now happen every other week. The subgroup for new entries will meet once a month, and the subgroup for modifying existing entries will also meet once a month. Alec has updated the calendar to reflect these changes. Steve emphasized that people could join any subgroup meeting even if they haven't signed up for a particular subgroup.
- **VulnCon 2025 Participation:** Erick and Steve mentioned that they will be presenting at VulnCon, and Erick encouraged WG members to find him there. Alex Summers and Chris Coffin will also be participating, with Chris presenting two sessions. Steve will be giving his presentation virtually.

Focus on New-Entry Development: “LLM Bad Practices: Improper Tuning of Model Control Parameters” (Lily Wong), ES-2406-9e5cf10

- **New Entry Discussion:** Steve led a discussion on the new entry submission by Lilly Wong on model parameter tuning, discussed in previous meetings of the CWE AI WG. The group discussed the name, description, and relationships of the weakness, as well as common consequences and mitigations.
 - Steve provided a link to the CWE AI WG Content Development Repository (CDR) in the chat for the group: <https://github.com/CWE-CAPEC/CWE-Content-Development-Repository/issues/114>
- **Inference Parameters:** The group agreed to use the term "inference parameters" instead of "hyperparameters" to describe the parameters used to guide AI behavior. This distinction helps clarify the focus on parameters set at inference time rather than during training.
 - **Clarification:** Erick and João provided clarification on the difference between hyperparameters and inference parameters, emphasizing that inference parameters are set at inference time and include settings like top P, top K, and temperature.
- **Extended Description:** The group continued the discussion with work on refining the extended description.
 - **Extended Description:** The group decided to work on refining the extended description for the new weakness entry in the CDR, incorporating technical nuances and important notes for developers.

- **Relationships:** The group discussed potential relationships for the new weakness entry, considering how it fits within the existing CWE hierarchical structure. They mentioned CWEs 440, 684, and 665 as potential related entries. There was some consensus around the relationship between this new entry and CWE-665, with Martin dissenting, pointing to CWE-440 as a better fit. Steve noted that while not ideal, CWE entries may have more than one parent
- **Common Consequences:** The group discussed the common consequences of the weakness, including generating inaccurate information, reduced reliability, and propagating errors in critical decision-making processes. They agreed to focus on the technical impacts rather than human trust.
 - **Inaccurate Information:** The group discussed that one of the common consequences of the weakness is the generation of inaccurate, misleading, or nonsensical information.
 - **Reduced Reliability:** Another consequence discussed was reduced reliability of the application or system utilizing the model, which can lead to technical issues such as denial of service or incorrect outputs.
 - **Critical Decision-Making:** The group also highlighted the propagation of errors in critical decision-making processes as a significant consequence of the weakness.
- **Next Steps:** Steve outlined the next steps, including refining the name and description, collecting an extended description, and discussing common consequences and mitigations in the CDR. The WG is also encouraged to work on observed examples and a detailed example of the weakness in code.
- **Encouragement for CDR Participation:** Erick closed out the WG meeting by encouraging participants to continue the discussion in the CDR and the groups.io mailing list to share thoughts, start discussion topics, and collaborate asynchronously.

Action Items:

- **GitHub Access:** Send GitHub usernames to cwe@mitre.org for access to CDR discussions. (All participants)
- **Subgroup Participation:** Express interest in joining the new entry or modification subgroups by adding your name to the chat or contacting the team. (All participants)

- **CDR Comments:** Review and comment on the CDR link provided for the new entry on improper configuration of generative machine learning model parameters. (All participants).